

Network Attacks and Hijacking

P2P 劫持 (P2P Hijacking)

1. Attacker send a command to P2P network: File is moved to <Victim's IP>
2. Victims will be flood by the legal requests from each computer on network

永久性阻斷服務攻擊 (Permanent DoS)

1. Attacker send a command to the control center: There is a firmware update
2. If the server auto update the malicious firmware, it'll be bricked

分佈式反射阻斷服務攻擊 (Distributed Reflection DoS, DRDoS)

1. Attacker send a fake packet with Victim's IP set to src to server
2. Multiple server recieved the command and response packet to Victim

多向量攻擊 (Multi-Vector Attack)。

- Layer 3 - Volumetric (體積式): 用流量塞報目標
- Layer 4 - Protocol (協定型): SYN Flood, TCP Handshake 讓伺服器無盡等待假 IP 而崩潰
- Layer 7 - Application (應用層): 模仿真實行為來癱瘓程式, e.g. HTTPS Requests

序列攻擊 (Sequential): 依序發動不同 Layer, 讓目標管理者不知道是哪裡出問題

平行攻擊 (Parallel): 以量取勝, 直接癱瘓防禦系統

分段攻擊 (Fragmentation Attack)

- The max packet size in network is called MTU (Default is 1500)
1. Attacker splitted a packet to multiple size under MTU
 2. But intentionally skip some fragment of them
 3. Server side will try to reassemble them and costs lots of performance

TCP SYN 泛洪攻擊 (SYN Flood Attack)

1. Attacker sends TCP packet with invalid src IP
2. Server will wait SYN from the invalud src IP and never gets response
3. Lots of TCP tunnel would filled up all the resources

Smurf 攻擊

1. Spoofing (偽造): Send a ICMP requests with victim's IP filled in src field
2. Amplification (放大): If there are 100 computer in network, 1 ICMP packet could cause 100 response to the victims. (ICMP 標準就是要回覆)
3. Crash (崩潰): Server side CPU will melt by the enormous requests

死亡之指 (PoD - Ping of Death)

1. Attacker sends ping command with illegal size (over 65535 Bit)
2. Packet need to be splitted to multiple fragment
3. Server will acclocate RAM to assemble them
4. But the fragment never ends, so it will buffer overflow eventually